FlowGuard: Contract-Aware Runtime Verification, Bounded Recovery & Side-Effect Idempotency for Agentic n8n Workflows

Author: Iyed Mohamed (ORCID: `0009-0008-9493-7510`, ESPRIT School of Engineering) | **Repository:** `https://github.com/iyedM/flowguard`

1. Core Research Question & Epistemic Scope

Research Question: *Does contract-aware runtime verification combined with bounded two-tier recovery and a 4-state idempotency lifecycle improve end-to-end state correctness in agentic n8n workflows under controlled failures, compared with native workflow handling, retries alone, and deterministic contract validation alone—and what are the measurable latency, token, and unrecoverable-failure trade-offs?*

Explicit Epistemic Labeling: Every module and experimental artifact in FlowGuard carries an explicit execution mode label to maintain strict scientific transparency: (1) `deterministic_harness` (JSON Schema Draft 2020-12 contract validator, least-privilege policy engine, and controlled fault injector); (2) `stateful_simulated_sink` (local stateful test services with ground-truth state verification and read-before-write reconciliation endpoints—never misrepresented as live production cloud clusters); (3) `live_llm_inference` (actual GPU inference via local `llama3:latest` on an NVIDIA GeForce RTX 2050 GPU); and (4) `exportable_n8n_workflow_json` (importable n8n workflow topologies in `workflows/*.json`).

2. Four-Mechanism Architecture & Separation of Security Boundary vs. Fallible Taint

FlowGuard interposes four runtime mechanisms between untrusted LLM reasoning steps and external side-effect sinks: **Mechanism A** (`flowguard/contracts.py`) enforces structural JSON Schema Draft 2020-12 contracts and cross-field domain invariants, emitting a 3-state verdict (`VALID`, `RECOVERABLE_VIOLATION`, or `UNSAFE_POLICY_BLOCK`). **Mechanism B** (`flowguard/recovery.py`) executes a Two-Tier Bounded Recovery loop: Tier-1 deterministically resolves known alias renames and scalar type coercions using 0 LLM tokens, while Tier-2 executes up to `max_repair_turns = 2` predicate-guided repair turns and re-validates every candidate through Mechanism A. **Mechanism C** (`flowguard/idempotency.py`) maintains a thread-safe SQLite WAL ledger (`busy_timeout=5000`) implementing a 4-state machine: `PENDING_IN_FLIGHT`, `COMMITTED`, `FAILED_SAFE_TO_RETRY`, and `AMBIGUOUS_REQUIRES_RECONCILIATION`. When a post-commit HTTP timeout occurs (the sink mutated state, but the HTTP response timed out in transit), Mechanism C transitions to `AMBIGUOUS_REQUIRES_RECONCILIATION` and queries the sink's reconciliation read endpoint before retrying, preventing duplicate side effects. **Mechanism D** (`flowguard/policy_guard.py`) strictly separates the **deterministic security boundary**—which depends exclusively on authoritative context attributes (`namespace=='prod-stateful-db'`, `cvss_score >= 7.0`, `secret_detected == True`, `team_monthly_budget_cap_usd`)—from the **fallible taint detector** (`is_authoritative_boundary = False`), which logs prompt-injection heuristics into OpenTelemetry spans strictly for auditability.

3. Experiment A: Multi-Domain Controlled Benchmark (720 Executions, 95% Wilson CIs)

We evaluate 180 controlled scenarios across three domains—**Domain 1 (AIOps Incident Remediation)**, **Domain 2 (DevSecOps CVE & Secret Triage)**, and **Domain 3 (Cloud & GPU FinOps Provisioning)**—spanning six fault classes (`F0_NOMINAL` through `F5_ADVERSARIAL_INPUT`) under four strategies (720 total executions).

Strategy / Domain	Runs	SVSR % [95% CI]	Recovery % [95% CI]	Unsafe SE %	Escape %	Escalation %	Tokens	p50 / p95 ms
B1_NATIVE_N8N (D1: AIOps)	60	16.67% [9.3, 28.0]	0.0% [0.0, 7.1]	58.33%	41.67%	0.00%	0.0	0.02 / 0.04
B1_NATIVE_N8N (D2: DevSecOps)	60	20.00% [11.8, 31.8]	4.0% [1.1, 13.5]	55.00%	38.33%	0.00%	0.0	0.02 / 0.04
B1_NATIVE_N8N (D3: FinOps)	60	20.00% [11.8, 31.8]	4.0% [1.1, 13.5]	55.00%	38.33%	0.00%	0.0	0.02 / 0.04
B1_NATIVE_N8N (ALL COMBINED)	180	18.89% [13.8, 25.2]	2.7% [1.0, 6.7]	56.11%	39.44%	0.00%	0.0	0.02 / 0.04
B2_NAIVE_RETRY (D1: AIOps)	60	25.00% [15.8, 37.2]	10.0% [4.3, 21.4]	70.00%	46.67%	0.00%	12.5	0.03 / 0.08
B2_NAIVE_RETRY (D2: DevSecOps)	60	28.33% [18.5, 40.8]	14.0% [7.0, 26.2]	66.67%	43.33%	0.00%	12.5	0.02 / 0.04
B2_NAIVE_RETRY (D3: FinOps)	60	28.33% [18.5, 40.8]	14.0% [7.0, 26.2]	66.67%	43.33%	0.00%	12.5	0.02 / 0.04
B2_NAIVE_RETRY (ALL COMBINED)	180	27.22% [21.2, 34.1]	12.7% [8.3, 18.9]	67.78%	44.44%	0.00%	12.5	0.02 / 0.05
B3_CONTRACT_ONLY (D1: AIOps)	60	33.33% [22.7, 45.9]	20.0% [11.2, 33.0]	16.67%	0.00%	66.67%	0.0	0.13 / 0.21

Strategy / Domain	Runs	SVSR % [95% CI]	Recovery % [95% CI]	Unsafe SE %	Escape %	Escalation %	Tokens	p50 / p95 ms
B3_CONTRACT_ONLY (D2: DevSecOps)	60	33.33% [22.7, 45.9]	20.0% [11.2, 33.0]	16.67%	0.00%	66.67%	0.0	0.13 / 0.17
B3_CONTRACT_ONLY (D3: FinOps)	60	33.33% [22.7, 45.9]	20.0% [11.2, 33.0]	16.67%	0.00%	66.67%	0.0	0.15 / 0.19
B3_CONTRACT_ONLY (ALL COMBINED)	180	33.33% [26.9, 40.5]	20.0% [14.4, 27.1]	16.67%	0.00%	66.67%	0.0	0.14 / 0.19
FLOWGUARD_FULL (D1: AIOps)	60	91.67% [81.9, 96.4]	90.0% [78.6, 95.7]	0.00%	0.00%	25.00%	90.3	0.62 / 1.57
FLOWGUARD_FULL (D2: DevSecOps)	60	90.00% [79.8, 95.3]	88.0% [76.2, 94.4]	0.00%	0.00%	26.67%	103.2	0.66 / 1.50
FLOWGUARD_FULL (D3: FinOps)	60	93.33% [84.1, 97.4]	92.0% [81.2, 96.8]	0.00%	0.00%	23.33%	76.2	0.66 / 1.40
FLOWGUARD_FULL (ALL COMBINED)	180	91.67% [86.7, 94.9]	90.0% [84.2, 93.8]	0.00%	0.00%	25.00%	89.9	0.65 / 1.55

Across all 180 scenarios combined, **FLOWGUARD_FULL** achieves a State-Verified Success Rate (SVSR) of **91.67%** (95% Wilson CI: [86.71%, 94.89%]) and a Fault Recovery Rate of **90.00%** ([84.16%, 93.85%]), compared with **18.89%** for `B1_NATIVE_N8N`, **27.22%** for `B2_NAIVE_RETRY`, and **33.33%** for `B3_CONTRACT_ONLY`. Crucially, `B2_NAIVE_RETRY` increases the Unsafe Side-Effect Rate from 56.11% to **67.78%** because blind retries re-execute mutations after post-commit HTTP timeouts.

4. Five-Way Ablation Study (900 Executions across 3 Domains)

Ablation Configuration	Domain Scope	SVSR % [95% CI]	Recovery %	Unsafe SE %	Escape %	Escalation %	Mean Tokens
full_flowguard	All Domains (N=180)	91.67% [86.7, 94.9]	90.00%	0.00%	0.00%	25.00%	89.92
no_tier1_drift_normalizer	All Domains (N=180)	81.67% [75.4, 86.6]	78.00%	0.00%	0.00%	35.00%	173.86
no_tier2_repair	All Domains (N=180)	75.00% [68.2, 80.8]	70.00%	0.00%	0.00%	41.67%	0.00
no_idempotency_reconciliation	All Domains (N=180)	85.00% [79.1, 89.5]	82.00%	6.67%	0.00%	25.00%	89.92
no_deterministic_policy_guard	All Domains (N=180)	78.89% [72.4, 84.2]	74.67%	12.78%	12.78%	16.67%	79.89

The ablation study confirms that each of the four mechanisms addresses a distinct failure surface: (1) Disabling Tier-1 symbolic normalization (`no_tier1_drift_normalizer`) reduces SVSR from 91.67% to **81.67%** while nearly doubling repair token consumption from 89.92 to **173.86** tokens/run. (2) Disabling Tier-2 bounded repair (`no_tier2_repair`) drops SVSR to **75.00%** and raises the Human Escalation Rate to **41.67%**. (3) Disabling post-commit timeout reconciliation (`no_idempotency_reconciliation`) causes duplicate mutations on every post-commit HTTP timeout, increasing Unsafe Side-Effect Rate from 0.00% to **6.67%**. (4) Disabling the deterministic policy guard (`no_deterministic_policy_guard`) and relying solely on regex taint detection allows subtle semantic injections to bypass the guard, resulting in a **12.78%** Unsafe Side-Effect Rate.

5. Experiment B: Live Local GPU Evaluation (llama3:latest)

To validate FlowGuard beyond deterministic fault traces, Experiment B executes **30 live workflow runs** (15 scenarios across AIOps, DevSecOps, and Cloud FinOps × 2 strategies) using real local inference with `llama3:latest` (digest: `365c0bd3c000a25d...`, 8.0B Q4_0, temperature=0.0) on the local NVIDIA GeForce RTX 2050 GPU.

Live Strategy / Domain	Runs	SVSR % [95% CI]	Unsafe SE %	Contract Escape %	Human Escalation %	Mean Tokens	GPU p50 / p95 (ms)
B2_NAIVE_RETRY (D1: AIOps)	5	20.00% [3.6, 62.5]	80.00%	60.00%	0.00%	201.6	13998.3 / 15775.0
B2_NAIVE_RETRY (D2: DevSecOps)	5	20.00% [3.6, 62.5]	80.00%	60.00%	0.00%	211.6	15126.8 / 16296.9
B2_NAIVE_RETRY (D3: FinOps)	5	20.00% [3.6, 62.5]	60.00%	80.00%	0.00%	229.8	19106.3 / 20195.3
B2_NAIVE_RETRY (ALL COMBINED)	15	20.00% [7.0, 45.2]	73.33%	66.67%	0.00%	214.3	15126.8 / 20028.6
FLOWGUARD_FULL (D1: AIOps)	5	100.00% [56.5, 100.0]	0.00%	0.00%	20.00%	355.6	14615.2 / 43646.9
FLOWGUARD_FULL (D2: DevSecOps)	5	100.00% [56.5, 100.0]	0.00%	0.00%	20.00%	364.2	15984.2 / 46501.1
FLOWGUARD_FULL (D3: FinOps)	5	80.00% [37.5, 96.4]	0.00%	0.00%	40.00%	667.6	19106.8 / 82141.0

Live Strategy / Domain	Runs	SVSR % [95% CI]	Unsafe SE %	Contract Escape %	Human Escalation %	Mean Tokens	GPU p50 / p95 (ms)
FLOWGUARD_FULL (ALL COMBINED)	15	93.33% [70.2, 98.8]	0.00%	0.00%	26.67%	462.5	16065.7 / 67130.9

In Experiment B, `B2_NAIVE_RETRY` achieves only **20.00%** SVSR with a **73.33%** Unsafe Side-Effect Rate, whereas **FLOWGUARD_FULL** achieves **93.33%** SVSR (95% CI: [70.18%, 98.81%]) with **0.00%** unsafe side effects, real GPU median latency `p50 = 16065.7 ms`, and tail latency `p95 = 67130.9 ms`.

6. Observed Failure Cases, Ambiguous Timeout States & Threats to Validity

1. Unrecoverable Schema Drift & Truncation Limits: FlowGuard does not achieve 100% recovery. Across the 180 scenarios in Experiment A, **15 fault scenarios (8.33% of all runs; 10.00% of fault-injected runs) fail recovery** and transition to `SAFE_ESCALATION_HALT`: (a) 3 persistent HTTP 503 sink outages that exceed the 2-attempt retry budget; (b) 6 catastrophic multi-field unknown schema drifts (e.g., proprietary SARIF/Terraform blobs with 3+ unmapped keys where Tier-1 alias tables and Tier-2 bounded repair cannot safely infer the missing action); and (c) 6 severely truncated LLM JSON streams cut off mid-token. Similarly, in Experiment B, scenario `LIVE-FINOPS-04` (proprietary unmapped schema keys) fails recovery and escalates to a human operator, yielding a live SVSR of **93.33%** (14/15 scenarios) and a Human Escalation Rate of **26.67%**.

2. Ambiguous Post-Commit Timeouts (`AMBIGUOUS_REQUIRES_RECONCILIATION`): Reconciling post-commit timeouts requires the downstream service to expose a read/query endpoint capable of inspecting recent state transitions or idempotency receipts. When a downstream sink lacks a read endpoint (`reconcile_fn=None`, tested in `test_02_post_commit_timeout_halt_when_reconcile_read_unavailable`), FlowGuard cannot automatically complete the retry and must halt in `AMBIGUOUS_REQUIRES_RECONCILIATION` for manual operator reconciliation.

3. Threats to Validity: *Internal validity:* Experiment A uses deterministic fault schedules and predicate-guided repair traces to guarantee reproducibility across 720 runs; we mitigate this by pairing it with Experiment B on live `llama3:latest` inference. *External validity:* Our sinks (`stateful_simulated_sink`) are local stateful emulators of Kubernetes, GitHub Actions/Trivy, and FinOps ledgers rather than multi-region cloud deployments; network jitter and distributed consensus delays in production may increase `p95` reconciliation latency. *Construct validity:* Heuristic taint detection on untrusted text is inherently incomplete against novel semantic paraphrases, which is why FlowGuard relies exclusively on deterministic attribute policies for its security boundary.